

One question.
Every database.
A receipt for every sentence.

Ariadne · federated knowledge for cybersecurity

Olmo S. Zavala Romero, PI · Brendon DGR, technical lead · FSU Scientific Computing

ReliaQuest Innovation Challenge · October 19, 2026

Security knowledge lives in databases that don't speak the same language

MITRE ATT&CK
speaks Cypher

MITRE CAPEC
speaks Gremlin

Customer identity graph
AD · Entra · Okta · AWS · GCP

The options today

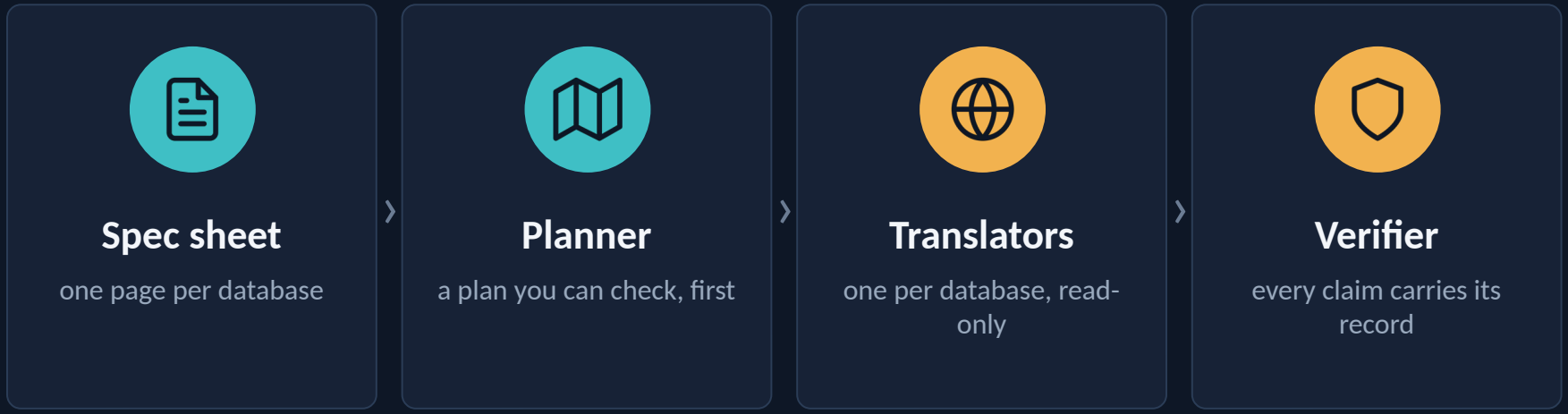
By hand — slow, every time

Copy it all into one warehouse — stale the day it lands

Ask a chatbot — it hallucinates

Hallucination — the AI states something as a fact that is not actually in the data.

Don't merge the databases. Federate the question.



No AI ever writes a query.

No claim without a record behind it.

What an answer looks like

Two real outputs from the evaluation record.

ASKED

“Which ATT&CK techniques does CAPEC-555 (Remote Services with Stolen Credentials) map to, and what mitigations apply?”

RAN (two databases, two languages, read-only)

```
g.V().hasLabel("AttackPattern").has("id", within(ids)).out("MAPS_TO")…
MATCH (t) WHERE t.attack_id IN $ids OPTIONAL MATCH (t)<-[:MITIGATES]-
(m:Mitigation) …
```

ANSWERED

CAPEC-555 maps to three ATT&CK techniques — T1021, T1114.002 and T1133 — with their mitigations. Every sentence cites the record it came from.

capec · CAPEC-555 | attack · T1021 | attack · T1114.002 | attack · T1133

When the data has nothing

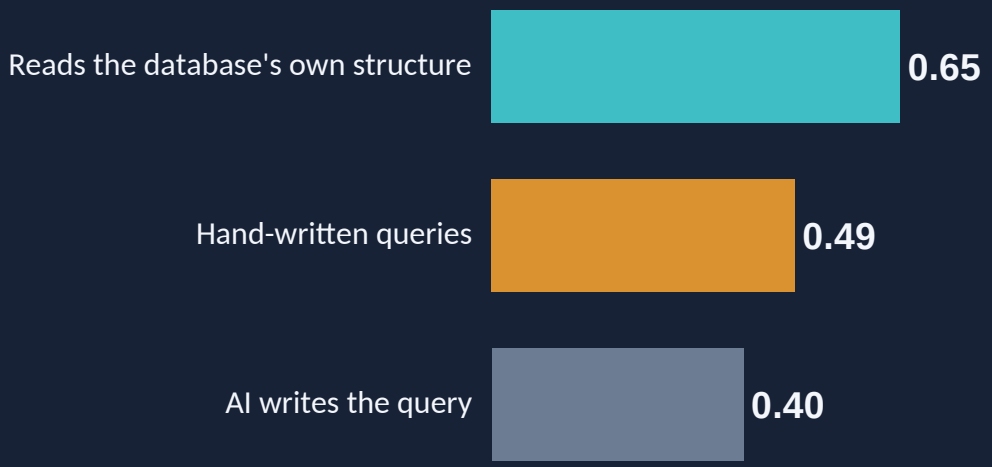
“Which ATT&CK techniques does CAPEC-116 map to?”

“The capec source doesn't establish this — the executed query ran cleanly and returned no matching records.”

0 claims made

0 invented mappings

288 held-back questions · three ways of answering



Two independent graders agree on the order.

4 s vs 2 days

hand-written vs AI-written queries, same questions

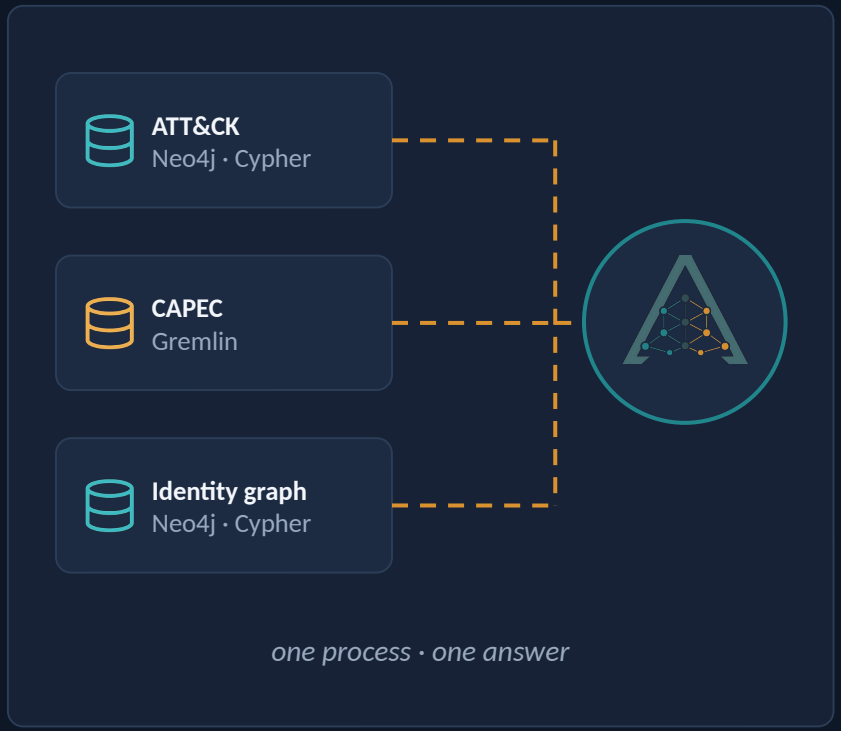
0

made-up claims — by construction

240 / 240

adversarial queries blocked

Adding a database is a spec sheet, not a project



3 databases · 2 languages · 1 process

nothing changed when the third was added

0 vs 1,083

records rewritten: federating vs merging

Next: Neptune, Spanner Graph

four documented swap points per engine

It already runs on ReliaQuest's own schema

What we received

72

node types

5

identity systems: AD · Entra · Okta · AWS · GCP

0

customer records — the spec sheet is enough

What happened

0.66 vs 0.13

right records found: reading the schema vs hand-written queries

12 / 12

unanswerable questions refused — no false claims

Bridge to ATT&CK

DC_SYNC = T1003.006

a relationship in your graph is a technique in theirs

"Which technique is what Domain Admins can do with DC_SYNC — and what mitigates it?"

We know where it breaks — that is the next step

Ask by identifier	Reword the question	Paraphrase the name
works	about half	0 of 104

1. **Close the vocabulary gap**
2. **Put a person in the loop**
3. **Pilot inside ReliaQuest**
4. **Neptune and Spanner Graph**



Questions?

Olmo S. Zavala Romero · Brendon DGR · FSU Scientific Computing

Backup

For questions. Every number sourced to the research record.

Backup · The full blind comparison

288 held-out questions (never seen, never graded before this run) and the 284-question development half. Paired bootstrap, 2,000 resamples.

Way of answering	Held-out (n=288)	95% CI	Dev half (n=284)	Second grader (gemma)
Reads the database's own structure (schema-assembled, no templates, no model)	**0.6546**	0.622 – 0.688	0.6569	0.6464
Hand-written queries (template cascade)	**0.4862**	0.453 – 0.520	0.4946	0.4320
AI writes the query (given schema, seeds, constraints, repair loop)	**0.4039**	0.372 – 0.435 *	0.3781	0.3678

Contrasts (held-out, qwen38-27B-v2): schema − hand-written +0.168 [+0.134, +0.205] · schema − AI-written +0.251 [+0.203, +0.300] · hand-written − AI-written +0.082 [+0.036, +0.131] (positive under both graders; significant under one). * CI from the first grading pass (0.4031); completed two-family pass reads 0.4039.

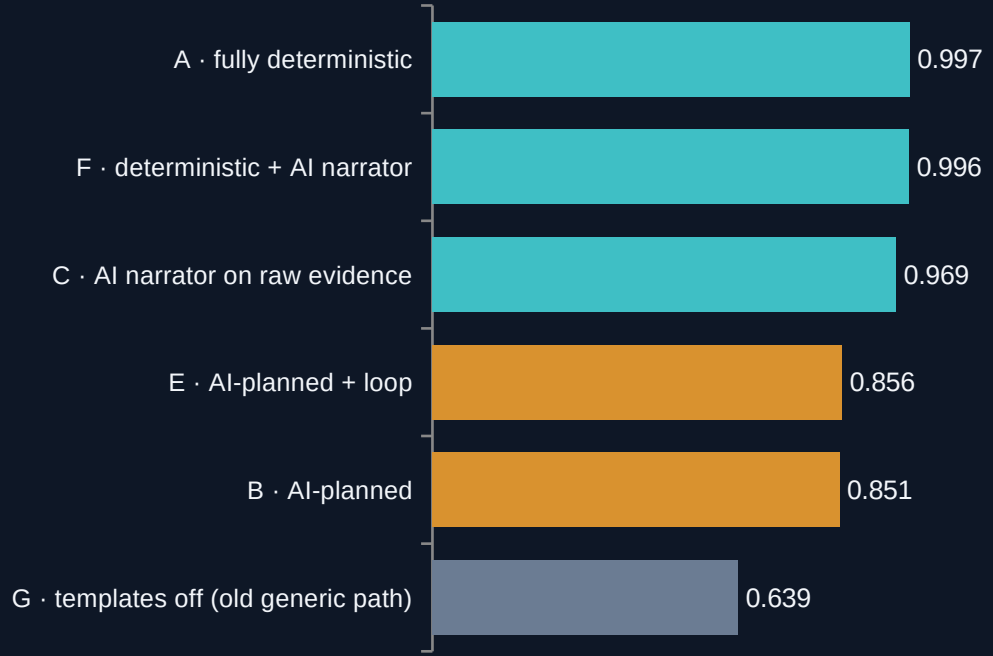
Cost: hand-written ≈ 4 s for 284 questions; AI-written ≈ 2 days of machine time (five attempts to make the baseline fair, all recorded).

Why these are lower than July's 0.99: July's 120 questions were co-authored with the code (bias measured at +0.03 to +0.05, same system, same grader). These are blind and hard on purpose. The finding is the ordering, which survives two grader families.

Sources: EXP-2026-09-007 data/judged-two-family-final.json (final) · EXP-2026-09-007/RESULTS.md (CIs) · docs/reports/2026-09-06-overnight-report.md · docs/reports/2026-09-05-full-report.md · C-021 (co-authorship bias)

Backup · The July study, kept as history

What we showed in August, and why we no longer lead with it.



What still stands

- Letting the AI plan is the biggest single loss (−0.12 to −0.14).
- Binding the AI narrator to verified claims costs 0.0015 — readable prose is free.
- Only 2 of 36 failures were the AI making things up; 26 were planning or retrieval.

What does not stand

- The 0.99 level: on 30 blind questions the same system scored 0.69. The questions were co-authored with the code.
- 'The templates hold the accuracy' (C-003): refuted. A schema-read path matches them on MITRE and beats them by roughly 0.5 on ReliaQuest's schema.
- The model that ran the AI-planned arms no longer exists behind that endpoint; the grader was an independent Sonnet 5 panel.

Sources: docs/evaluation/2026-07-26/README.md · docs/research/CLAIMS.md (C-001, C-002, C-003, C-005, C-013, C-016) · README.md 'The July arm study, kept as history'

Backup · Federate vs. merge, and the safety audit

Federating vs. merging into one warehouse

Accuracy: no demonstrable difference. Six readings across two blind banks and three graders — federation at or above merging in all six (0.00 to +0.06), demonstrably ahead in none (±0.06 question-sampling floor at n=30). We do not claim federation is more accurate.

Structure: the difference is real. Merging ATT&CK and CAPEC into one store required adding a property to 1,083 of 9,138 nodes (894 CAPEC nodes given an identifier the upstream record does not carry; 189 ATT&CK entries re-prefixed). The store is no longer what MITRE published, the edit must be re-applied on every release, and a consumer cannot tell the publisher's field from ours. Federation edited 0. The customer identity graph loaded unmodified.

Why it matters for ReliaQuest: customer telemetry and licensed feeds have different owners, retention rules and access controls. They cannot always be copied. They can always be asked.

Query safety audit

240 / 240
adversarial probes blocked, 0 leaks

15
real bypasses found by us — and closed

The original 17 hand-written probes all passed — weak evidence of a strong property. Generating 240 by crossing rejection categories with syntactic mutations found 15 genuine gaps: TinkerPop's mutating mergeV/mergeE steps that no spec sheet named (8), a server-side Groovy closure (1), un-checked repeat() depth (2), a literal 4-hop chain that evaded the depth cap (1), a USE-database switch (1) and two label-smuggling variants. All closed; block rate now 1.000.

Cross-tenant isolation: 14 probes across three live sources; the shipped routing rule leaks 5 records on 1 probe vs. 568 on 3 for the naive rule (−99.1%). One residual leak is recorded, not hidden.

Sources: EXP-2026-08-009 + A-1 · EXP-2026-08-017 · EXP-2026-09-006 (C-022 across grader families) · EXP-2026-08-016 (240 probes) · CLAIMS.md C-008, C-022

Backup · What a spec sheet (source card) looks like

One JSON file per database. The planner routes only on what it declares; the translators bound every query by it.

```
{
  "dataset": "attack",
  "runtime_backend": "neo4j",
  "provenance": {
    "source_name": "MITRE ATT&CK", "dataset_version": "v19.0",
    "snapshot_pinned": true, "raw_sha256": "…"
  },
  "node_labels": [ 11 labels ], "relationship_types": [ 9 types ],
  "identity": {
    "join_key": ["attack_id", "stix_type"],
    "policy": "Two records may be joined only if BOTH
               attack_id AND stix_type match."
  },
  "safety": {
    "read_only": true,
    "disallowed_clauses":
["CREATE","MERGE","DELETE","SET","REMOVE","DROP"],
    "max_result_rows": 1000,
    "max_traversal_depth": 3,
    "query_timeout_ms": 5000
  }
}
```

Provenance
Which snapshot, pinned by hash. Every answer can say which version it read.

Identity
What counts as 'the same thing' across databases — the join rule. For ReliaQuest's identity graph, where no shared ID exists, a reviewed correspondence table (DC_SYNC → T1003.006) plays this role.

Safety
What a query may never do. Enforced before execution, on every query, by code — not by asking a model nicely.

Adding a database = writing this file (a generator drafts it from the live schema) plus, for cross-database questions, the correspondence table.

Sources: data/source_cards/attack.json (excerpt, abridged) · docs/source_cards.md · utils/planner/edge_correspondence.py